

SRC漏洞挖掘经验分享

最近发现很多刚接触渗透方面的小伙伴都不知道实战挖掘漏洞的诀窍，于是我打算写一些自己挖漏洞的诀窍。

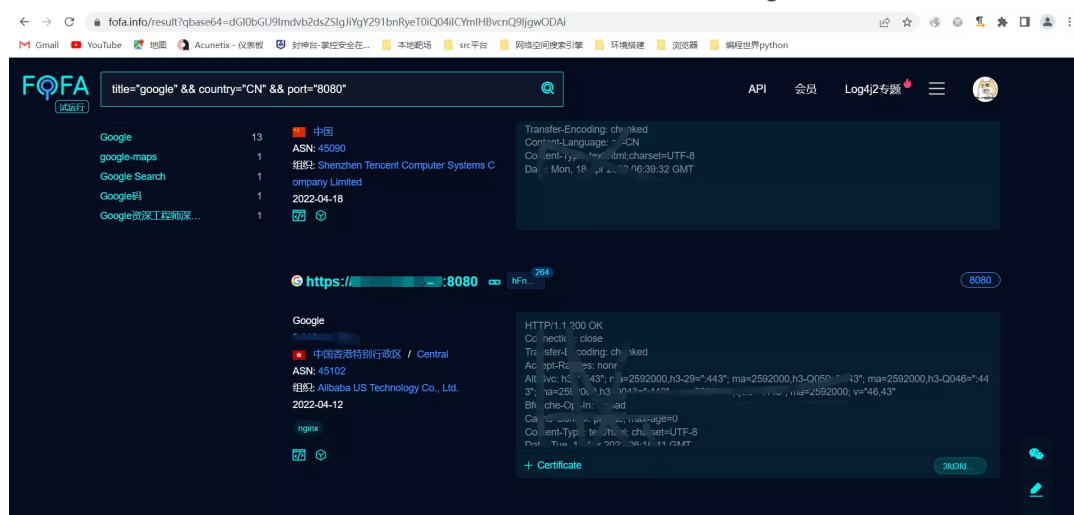
src推荐新手挖洞首选漏洞盒子，因为漏洞盒子范围广，国内的站点都收。相比于其他src平台，挖掘难度很适合新手。

漏洞挖掘，信息收集很重要。

这里以部分实战展开讲解。

首先说一下谷歌语法吧！！

如下可通过fofa、钟馗之眼、shodan等网络空间搜索引擎搜索Google镜像。

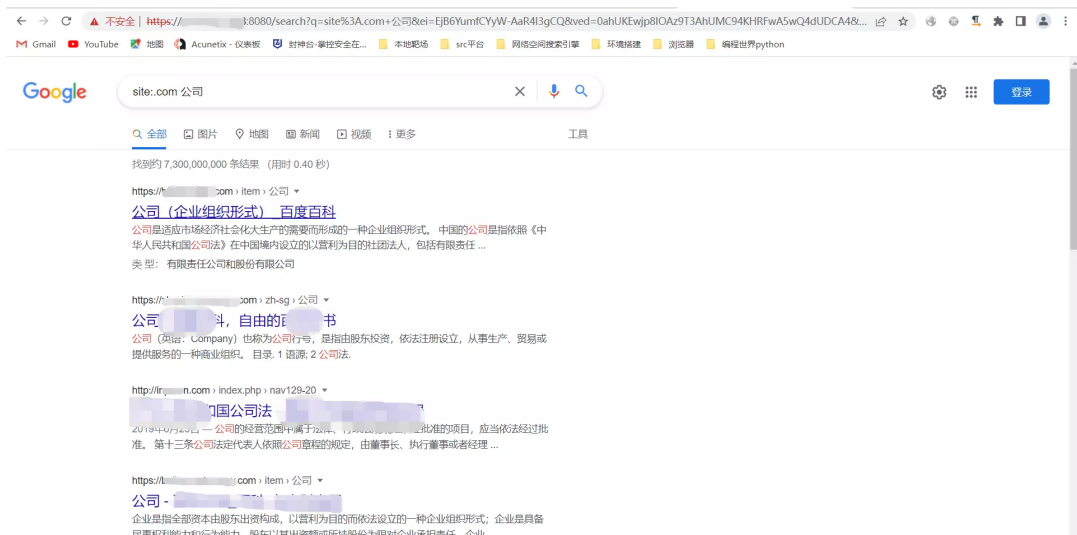


SQL注入挖洞基本流畅

- 1.找漏洞，通过基本的site、inurl:谷歌语法。
- 2.找到一个站点，各种点点点，找他的注入点。
- 3.找不到注入点，信息收集。
- 4.然后就是一些列操作。

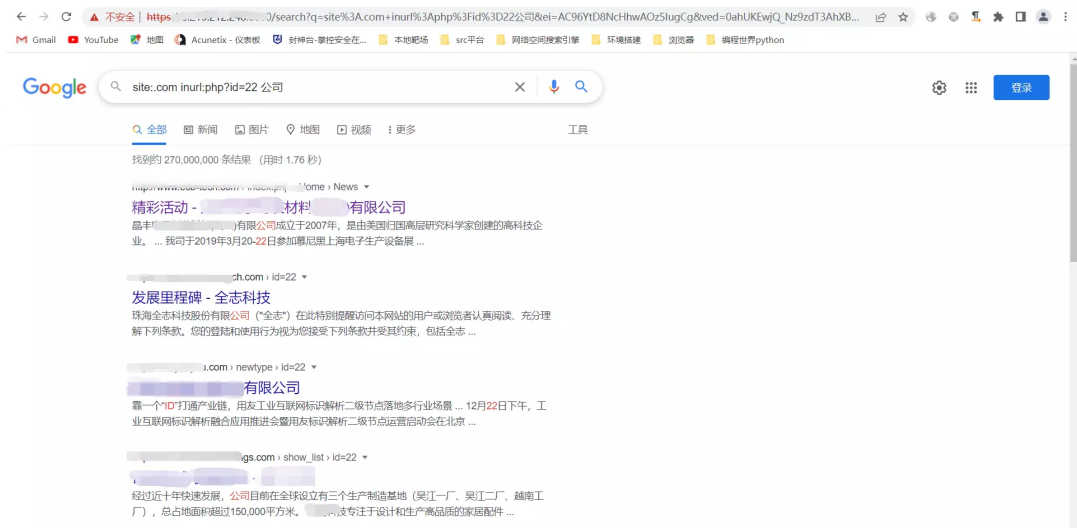
打开Google镜像，输入我们的谷歌语法site:.com 公司。

这样就会得出域名以.com为后缀相关的公司名称，在后面加个公司的意义就是指定为公司名称筛选。



谷歌语法，通过谷歌浏览器搜索：site:.com inurl:php?id=22 公司

这里加上了php?id=22，因为咱们的注入点核心在于传参，所以搜索传参会更加容易找到漏洞。

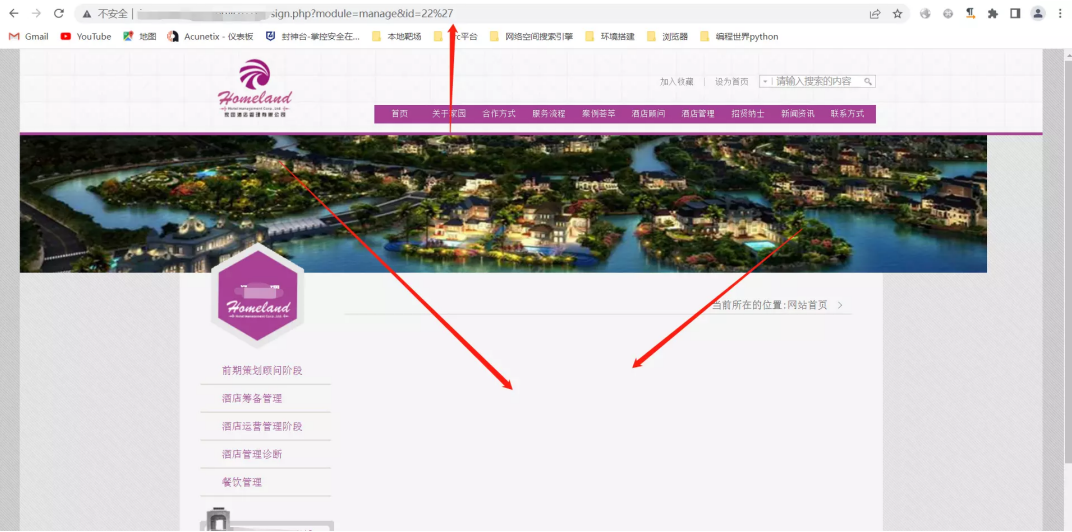


下面我们找到一个网站进行测试。



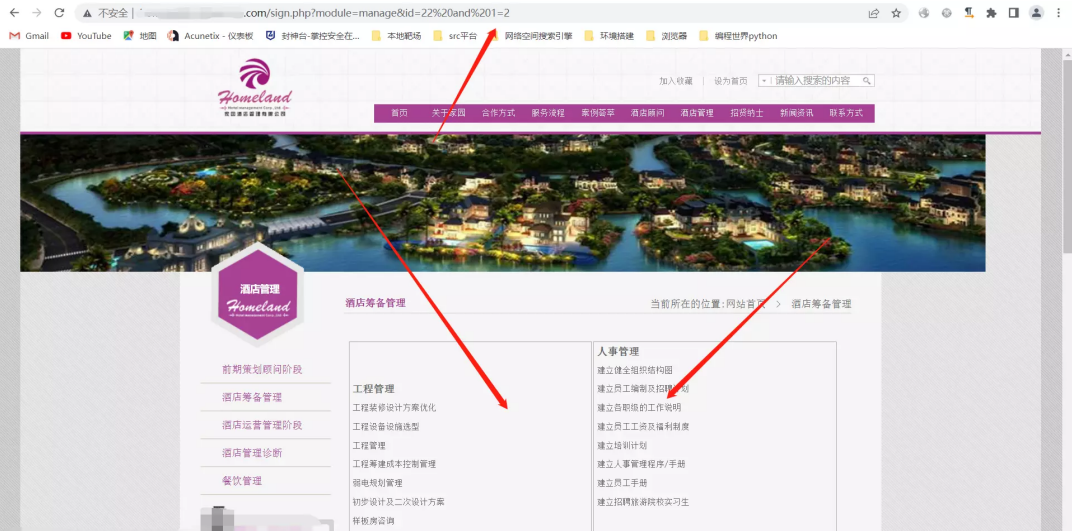
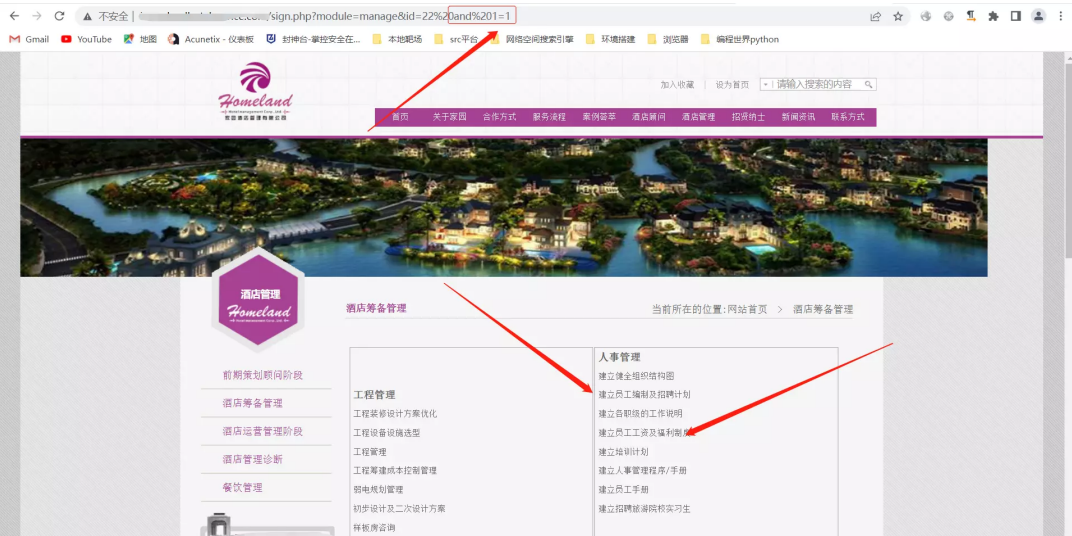
首先我们输入单引号: '，看页面发生了变化。

这说明我们输入的单引号被执行，发生了报错。这里就极大可能存在SQL注入。



进一步使用, and 1=1 && and 1=2,进行验证漏洞是否存在。

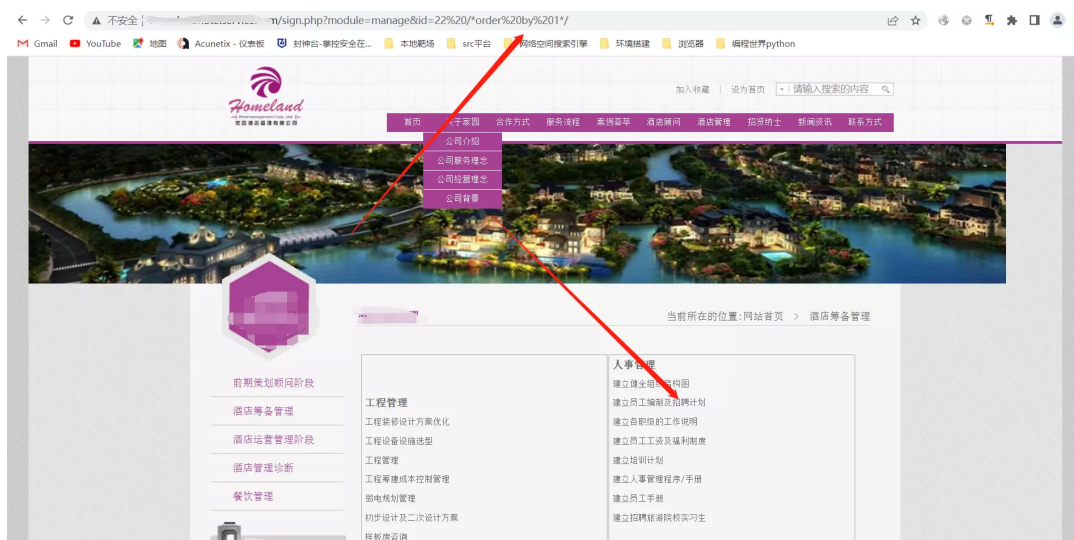
这里的and 1=1，页面正常，但在 and 1=2 的时候，页面也是回显正常，进一步验证。



我们继续使用SQL语句函数，得出结论，我们被网站防火墙拦截了。

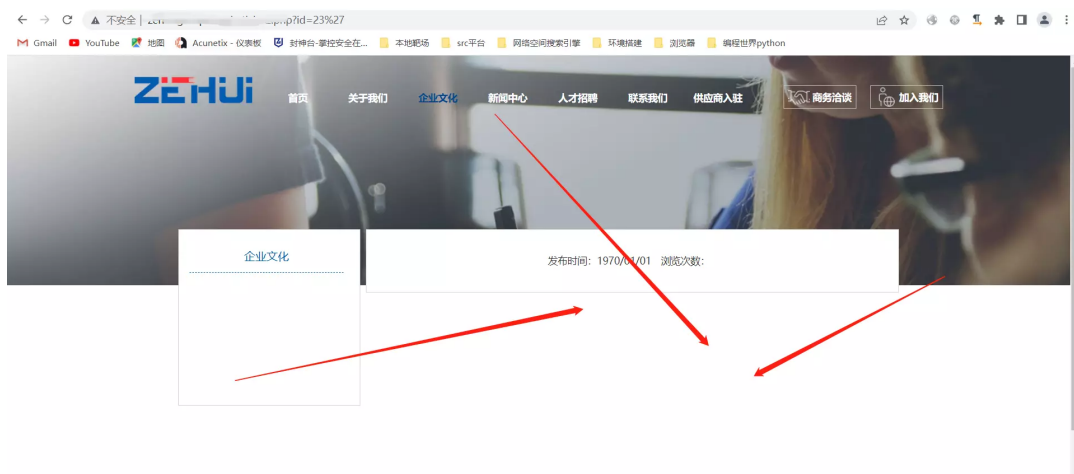


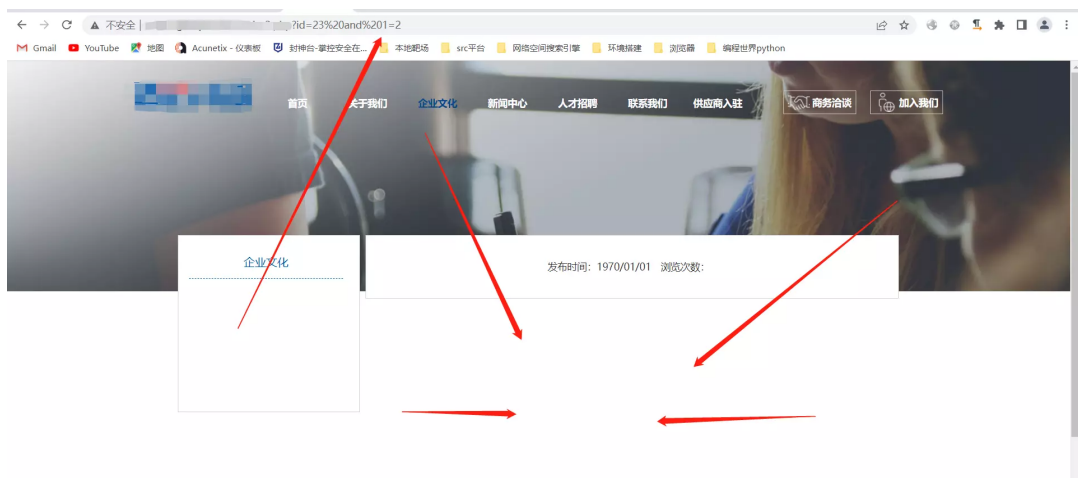
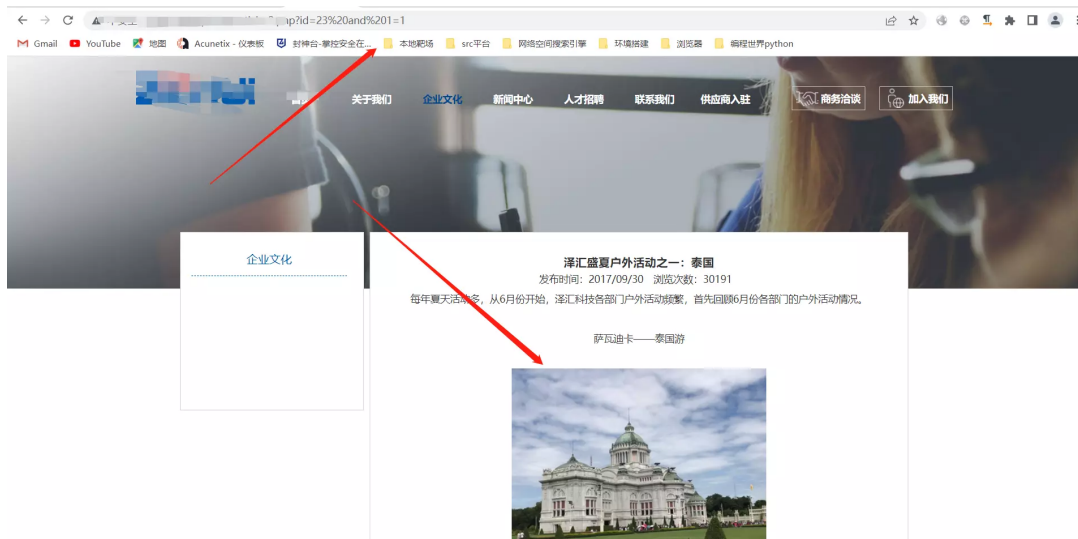
没绕过网站防火墙, 这里随便试了一下内联注释法, 执行成功了。绕防火墙太繁琐, 我就做多操作了, 对于新手来说, 遇到防火墙可以直接撤退了。



下面找到一个站, 输入单引号', 页面异常, 我们找输入and 1=1 | 1=2, 发现1=2异常。

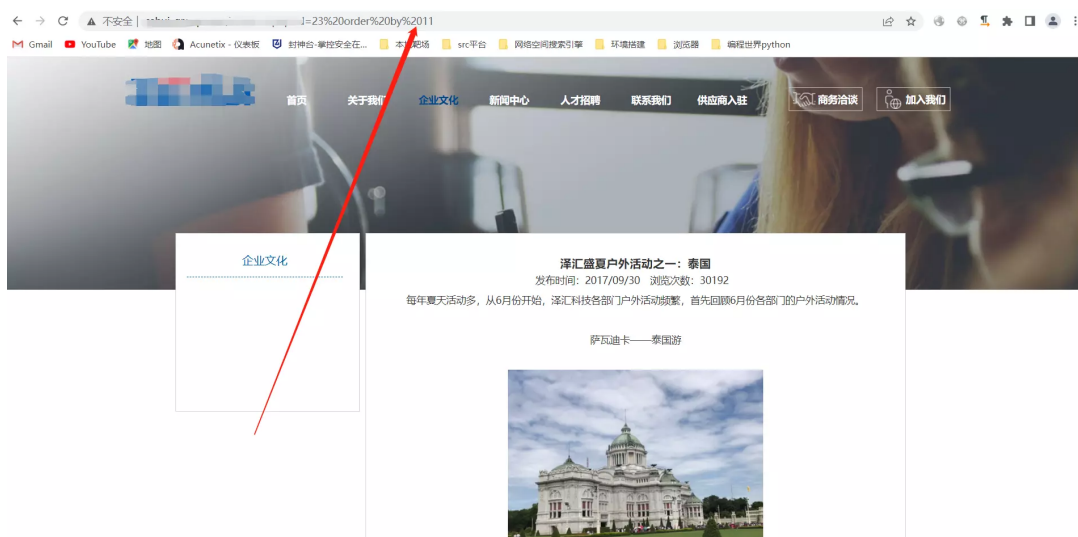
说明我们输入的函数被数据库执行, 存在SQL注入。

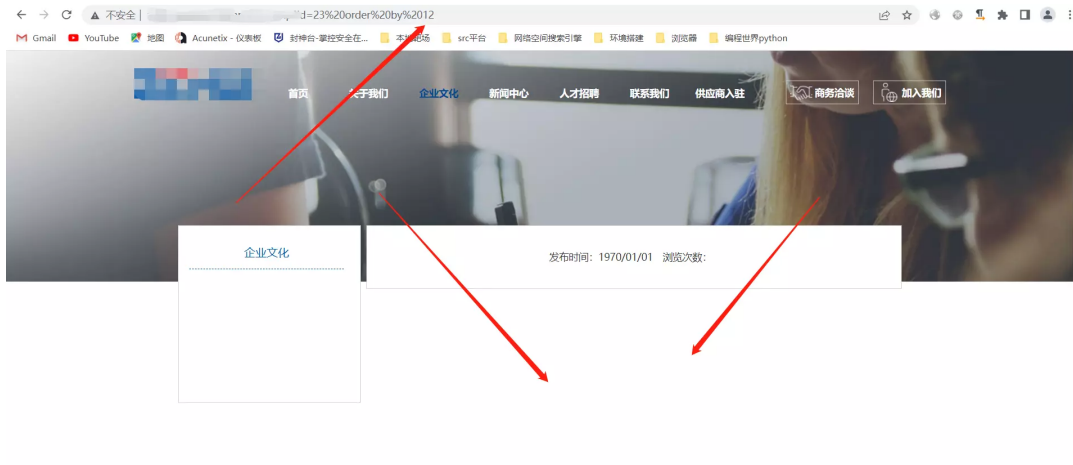




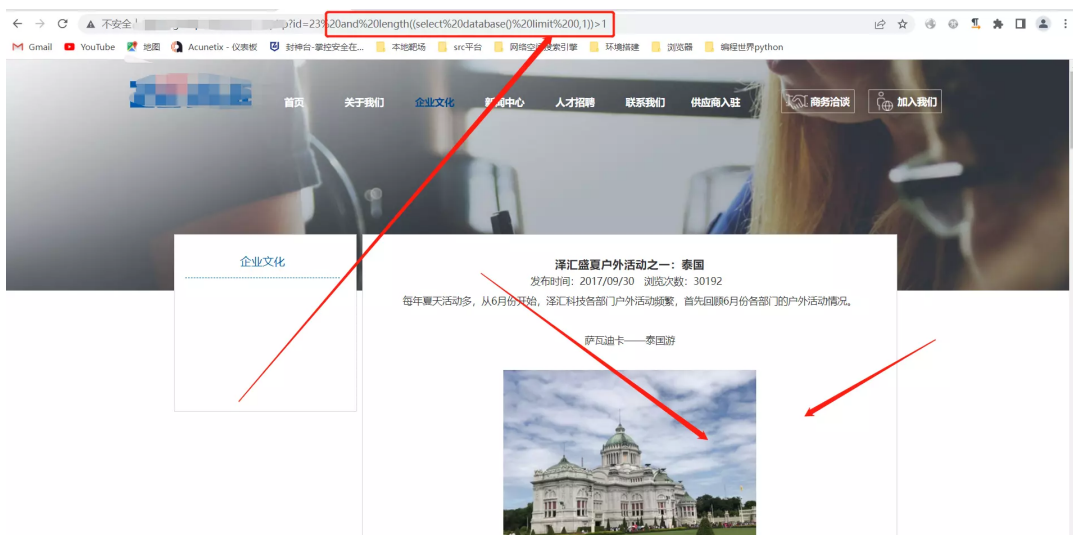
已经测试漏洞存，接下来看能否验证漏洞。上SQL语句，我们使用order by 11 | order by 12。

order by 11 页面正常，而order by 12 页面异常（说明存在11个字段）。

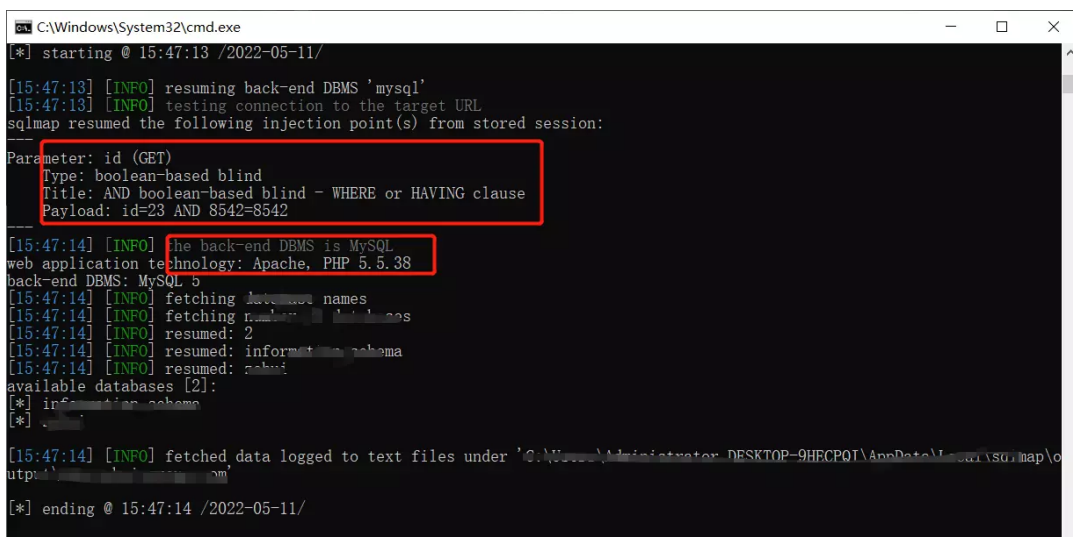




然后我们运用SQL语句，发现这里存在布尔盲注，布尔盲注查询数据繁琐，这里直接丢SQLmap跑了。



sqlmap命令: Python sqlmap.py -u 目标URL --dbs (指定目标跑库名)，最后成功得出库名。

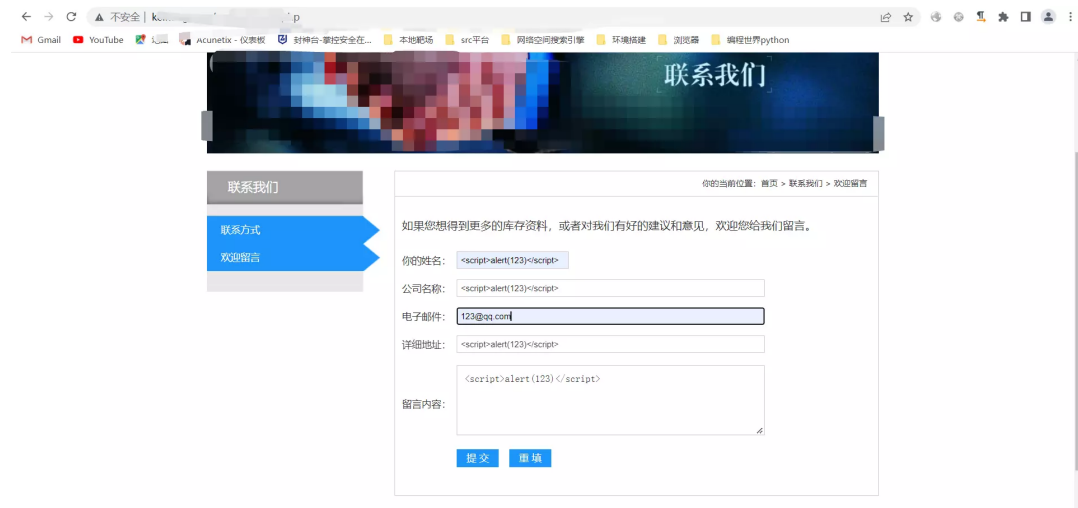


挖洞就是这么的轻轻松松，SQL注入还是特别多的，遇到waf，有想法的可以去尝试绕过。

XSS漏洞

一般通过搜索到的站点看是否有留言板，可以尝试盲打XSS，一般一个XSS为中危，直接构建xss语句：`<script>alert(1)</script>`，见框直接插就行了，弹窗就直接提交src平台就行了。

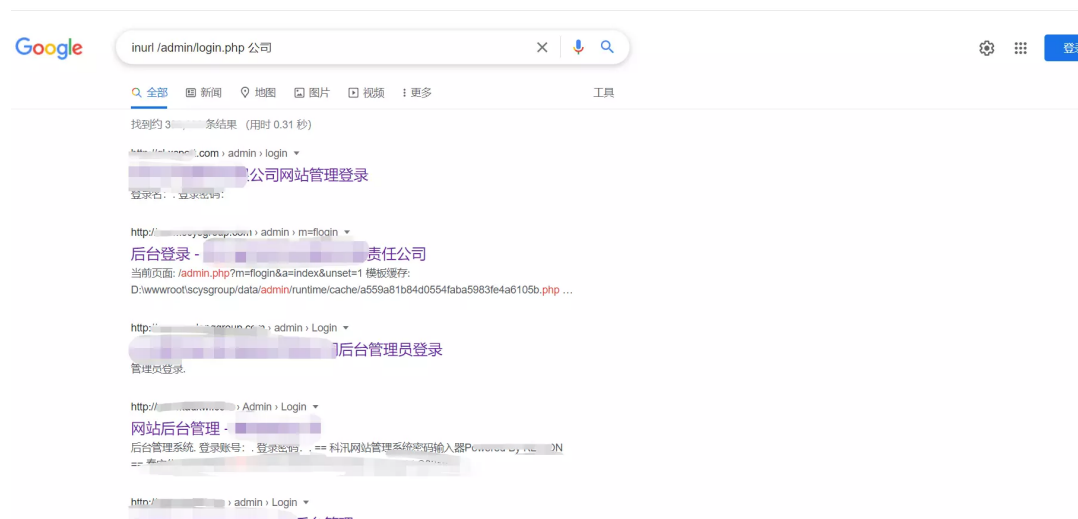
XSS一般留言板！！



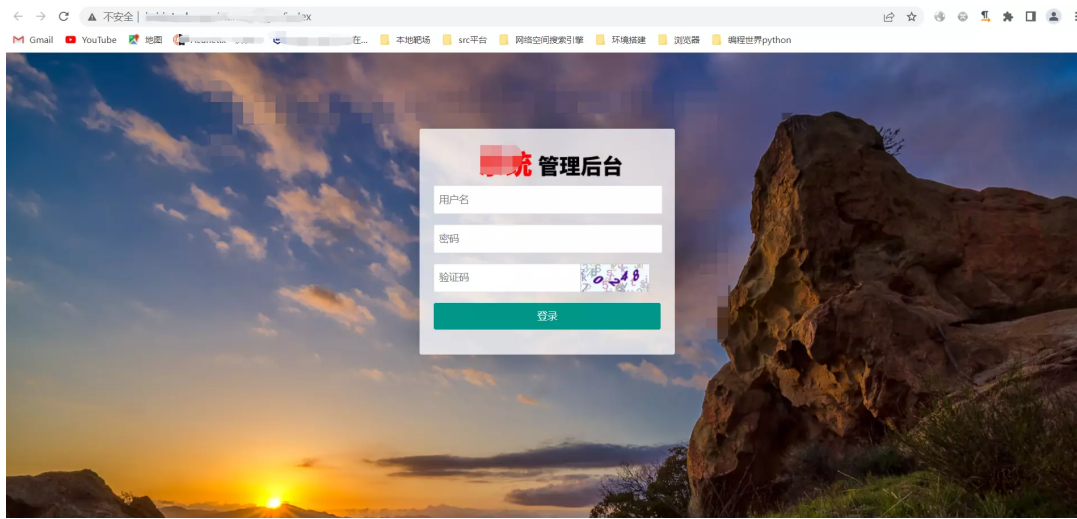
弱口令漏洞挖掘

弱口令的谷歌语法：`inurl:admin/login.php` 公司。

这样就可以搜到很多公司的后台咯。



进入后台可以使用工具批量去爆破弱口令了，如`admin/111111`等,还可以通过查看js代码查看是否存在账号密码。



可以去使用或自己构建弱口令爆破工具，这种工具特别多，就不多阐述了。

有的验证码就是摆设的，也有抓住包就不会变化的验证码。

这些都是挖掘src比较推荐的漏洞，祝大家早日登上榜坐！！